

24MNG432 — INFORMATION SECURITY AND RISK MANAGEMENT

Class: 2023 Batch CYS | Semester 7 | Academic Year 2026–27 (Odd Semester)

Assignment 1 — Business Continuity Planning, Disaster Recovery and Risk Management

Case Study: Amirtha MedCare Hospital — Monsoon Flood, Infrastructure Failure and Ransomware Incident

Scenario summary. Amirtha MedCare Hospital is a 700-bed multi-specialty facility in a coastal city, running emergency care, telemedicine, online appointments, EHR, laboratory, pharmacy and digital payments across one on-campus primary data centre, one backup server 40 km away, 250 desktops and 900 employees. During peak monsoon, a compound event occurs: flooding and water ingress into the server room, loss of internet, primary database outage, failure of poorly maintained generators, and a ransomware attack encrypting file servers — producing simultaneous clinical, financial and reputational impact. This report addresses risk identification, business impact analysis, business continuity planning, quantitative risk assessment, disaster recovery and the first-24-hour crisis management strategy.

1. Risk Identification and Classification

Sixteen distinct risks are identified from the scenario and classified into the five prescribed categories. A single physical event (flooding) cascades into technological, human and cyber risks — this is a *compound* or *concurrent* disaster, which is precisely the condition most single-threaded continuity plans fail to handle.

#	Risk	Classification	Description / Trigger	Primary Consequence
1	Coastal flooding of hospital campus	Natural Disaster	Continuous monsoon rainfall, poor storm-water drainage, low-lying coastal location	Physical inaccessibility, damage to ground-floor assets, staff and ambulance movement blocked
2	Water ingress into server room damaging network equipment	Natural Disaster (cascading to Technological Hazard)	Server room sited without flood-proofing or raised flooring; switches, routers and UPS submerged	Total LAN/core-switch failure; all campus IT services unreachable
3	Loss of internet / WAN connectivity	Technological Hazard	Single ISP link, no redundant last-mile or 4G/5G failover; last-mile fibre damaged by flooding	Telemedicine, cloud email, payment gateway, GPS tracking and DR replication all down
4	Primary EHR database server unavailable	Technological Hazard	Single-instance database with no active-active cluster or automatic failover	Clinicians lose access to patient history, allergies, drug charts and orders
5	Emergency diesel generator failure	Human Error (maintenance negligence)	Missed load-bank testing, stale fuel, no preventive maintenance schedule, generators sited at flood level	Loss of backup power to ICU, OT, ventilators, servers and cold-chain storage — direct life-safety risk
6	Ransomware encrypting file servers	Cybersecurity Threat	Likely phishing or exposed RDP/VPN; flat network with no segmentation; attacker times the strike to the disaster window	Encryption of shared clinical/administrative files; possible spread to backups; extortion demand
7	Initial-access vector: phishing / weak remote access	Human Error + Cybersecurity Threat	Staff clicking malicious mail during crisis; shared or reused credentials; no MFA on remote access	Domain-level compromise, lateral movement, privilege escalation
8	Exfiltration and breach of Protected Health Information (PHI)	Cybersecurity Threat	Double-extortion ransomware exfiltrates EHR data before encrypting	Statutory penalty under DPDP Act 2023 and IT Act §43A/§72A, CERT-In 6-hour reporting obligation, patient lawsuits

#	Risk	Classification	Description / Trigger	Primary Consequence
9	Backup site located only 40 km away in the same coastal flood belt	Human Error (design/planning failure)	DR site inside the same weather and power grid footprint; violates geographic-diversity principle	Correlated failure — primary and backup can be lost by one regional event
10	Backup integrity / restoration failure	Technological Hazard	Backups never test-restored; online/network-mounted backups reachable by ransomware; no immutable or air-gapped copy	Permanent data loss, forced ransom consideration, unrecoverable RPO
11	Laboratory Information System (LIS) unavailability delaying surgery	Technological Hazard (patient-safety impact)	Lab reports not retrievable; no printed or downtime copy at point of care	Elective and emergency surgeries postponed; deterioration of waiting patients
12	Pharmacy unable to verify prescriptions	Technological Hazard (operational)	e-Prescription and drug-interaction checking module offline; no downtime prescription register	Medication error, wrong-drug or wrong-dose dispensing, controlled-substance accountability gaps
13	Ambulance GPS tracking system failure	Technological Hazard	Dependent on the same failed internet link and central server	Blind fleet dispatch during a flood, delayed emergency response, increased mortality risk
14	CCTV surveillance and biometric attendance outage	Technological Hazard (enabling Intentional Attack)	Physical security controls depend on the same power and network	No monitoring of restricted areas, unrecorded access to pharmacy narcotics store and server room, tailgating
15	Theft, looting or malicious physical access during the outage	Terrorist / Intentional Attack	Opportunistic intrusion while CCTV, access control and staffing are degraded	Loss of drugs, equipment and physical records; possible deliberate sabotage of recovery
16	Reputational damage from social-media misinformation	Human Error (communication failure; Intentional if coordinated)	No holding statement issued; information vacuum filled by rumour; possible attacker-driven pressure campaign	Patient panic, self-discharge, diversion of new admissions, loss of public trust and revenue
17	Staff unavailability and fatigue	Natural Disaster (secondary human impact)	Employees cannot reach the hospital through flooded roads; on-duty staff work extended shifts	Reduced clinical capacity, higher error rate, no relief rotation
18	Vendor / third-party SLA failure during the monsoon	Technological Hazard + Human Error	ISP, HIS vendor, generator AMC and cloud provider all under regional stress; no pre-negotiated emergency SLA	Recovery times stretch far beyond planned RTO; no accountable escalation path

Key observation. Risks 2, 5, 9 and 10 are not "bad luck" — they are *pre-existing control failures* that the flood merely exposed. A server room at flood level, untested generators, a DR site inside the same hazard zone, and unverified backups are governance defects. The flood is the trigger; the vulnerability was designed in.

2. Business Impact Analysis (BIA)

The BIA determines *what* must be recovered and *in what order*, independent of how it will be recovered. Three parameters are used:

- **MTD / MAD (Maximum Tolerable Downtime / Maximum Acceptable Downtime)** — the outage duration beyond which the impact becomes unacceptable to patient safety, law or the survival of the business function.
- **RTO (Recovery Time Objective)** — the targeted restoration time, always shorter than MTD to leave a safety margin.
- **RPO (Recovery Point Objective)** — the maximum tolerable data loss measured backwards from the point of failure.

#	Critical Service	Business Function	Impact if Unavailable	MTD / MAD	RTO	RPO	Recovery Priority
1	Emergency & Critical Care (Casualty, ICU, OT, ventilators, life-support power)	Life-preserving clinical care; triage and stabilisation of incoming flood casualties	Immediate loss of life. Ventilators, monitors, infusion pumps and OT lights stop without power. Legally and ethically non-negotiable; also the single largest liability exposure.	0–15 min	Immediate	0	HIGH
2	Electronic Health Record (EHR) database	Single source of truth for diagnosis, allergies, medication history, orders and clinical notes	Doctors prescribe blind — risk of allergic reaction, drug interaction and duplicated or contraindicated treatment. Blocks admissions, discharges, surgery and billing. Regulatory record-keeping breached.	1 hour	≤ 30 min (read-only)	≤ 15 min	HIGH
3	Laboratory Information System (LIS + analysers + report delivery)	Diagnostic results: pre-operative clearance, blood grouping and cross-match, critical-value alerts	Surgeries cannot proceed without pre-op reports; transfusion cannot be safely issued without cross-match. Sepsis and trauma management delayed. Directly matches the scenario's blocked surgical queue.	2 hours	≤ 1 hour	≤ 15 min	HIGH
4	Pharmacy management & prescription verification	Dispensing, drug-interaction checking, stock and narcotics control, cold-chain tracking	Medication errors, wrong dose or wrong drug, inability to verify authenticity of prescriptions, loss of Schedule H/X narcotics accountability, spoilage of refrigerated drugs and vaccines.	2–4 hours	≤ 2 hours	≤ 30 min	HIGH
5	Core network, power and internet connectivity (LAN, core switch, UPS, generator, WAN)	Enabling infrastructure on which every other digital service depends	Universal dependency — nothing else can be recovered until this is restored. Also blocks DR replication, cloud email, remote vendor support and payment settlement.	1 hour	≤ 1 hour	N/A	HIGH
6	Ambulance GPS tracking & emergency dispatch	Fleet location, routing around flooded roads, pre-arrival notification to casualty	Blind dispatch during a mass-casualty flood event; ambulances routed into submerged roads; casualty unprepared for arriving patients; measurable increase in pre-hospital mortality.	30–60 min	≤ 1 hour	≤ 1 hour	HIGH
7	Radiology / PACS imaging	X-ray, CT and ultrasound acquisition and reporting for trauma and pre-operative assessment	Trauma and head-injury management delayed; images acquired but unreportable; surgical decisions deferred.	4 hours	≤ 3 hours	≤ 1 hour	HIGH
8	CCTV surveillance & physical access control	Monitoring of restricted areas: server room, narcotics store, blood bank, maternity ward	No deterrence or forensic record during the period of highest opportunistic risk; unrecorded entry to the compromised server room destroys the forensic chain of custody.	4–8 hours	≤ 6 hours	≤ 4 hours	MEDIUM

#	Critical Service	Business Function	Impact if Unavailable	MTD / MAD	RTO	RPO	Recovery Priority
9	Online payment gateway & billing	Revenue collection, insurance and TPA pre-authorisation, discharge settlement	Cash-flow interruption and discharge backlog occupying beds needed for flood casualties. Tolerable short-term through manual receipting; PCI-DSS obligations persist.	24 hours	≤ 12 hours	≤ 1 hour	MEDIUM
10	Telemedicine & online appointment booking	Remote consultation and outpatient scheduling	Outpatient revenue loss and patient dissatisfaction; partially mitigated because elective outpatient load is reduced during a flood. Can run on phone-based triage.	12–24 hours	≤ 24 hours	≤ 4 hours	MEDIUM
11	Cloud-based email	Internal coordination, vendor and regulator correspondence	Cloud-hosted, so data survives; only access is lost. Substitutable by mobile data, SMS and the emergency call tree.	8–12 hours	≤ 8 hours	≤ 1 hour	MEDIUM
12	Biometric attendance system	Payroll input, shift and duty-roster verification	No clinical or safety impact. Fully substitutable by manual muster rolls and supervisor sign-off; reconciled retrospectively.	72 hours+	≤ 72 hours	≤ 24 hours	LOW

Recovery sequence derived from the BIA.

Power & life-support → Core network & connectivity → EHR (read-only first, then read-write) → LIS → Pharmacy → Ambulance GPS → PACS → CCTV → Billing / payment gateway → Telemedicine & appointments → Email → Biometric attendance.

Principle: restore in descending order of patient-safety impact, not in ascending order of technical convenience. An "EHR read-only" tier is deliberately created — giving clinicians *read* access to history within 30 minutes removes the largest clinical risk long before full transactional service returns.

3. Business Continuity Plan (BCP)

The BCP keeps the hospital *functioning* during the disruption; the DRP (Section 5) restores the technology. Continuity of care must not wait for continuity of computing.

3.1 Emergency Response Procedures

1. **Detect and raise alarm (0–5 min).** Any staff member observing flooding, power loss or a ransom note calls the 24×7 Emergency Control Number. No employee is required to assess severity before reporting.
2. **Life-safety first.** Shift ICU/OT patients to manual bag-valve ventilation and battery-backed transport monitors; confirm oxygen manifold and medical-gas supply; account for all patients, staff and visitors.
3. **Isolate electrical hazards.** Facilities isolates power to the flooded server room before anyone enters — standing water plus live electricity is a fatal hazard. Never enter to "save the servers".
4. **Network containment (cyber).** Immediately disconnect the WAN uplink and physically isolate affected VLANs to stop ransomware propagation. Power down nothing that may hold volatile forensic evidence unless it is actively encrypting.
5. **Activate the Emergency Operations Centre (EOC)** at a pre-designated, elevated, dry location with independent power (upper-floor conference room) and a satellite/4G uplink.
6. **Declare the disaster.** Only the Incident Commander (CEO or delegate) may formally declare, which authorises BCP/DRP activation, emergency spend and vendor invocation.
7. **Switch to Downtime Mode.** Distribute pre-printed downtime kits: paper case sheets, prescription pads, lab requisition forms, transfusion request forms, MRN sticker sheets and a manual patient-tracking board.
8. **Ambulance diversion.** Notify the district EMS control room to divert non-critical incoming ambulances to partner hospitals; retain only cases the hospital can safely treat in degraded mode.
9. **Preserve evidence.** Photograph the ransom note, capture memory and logs where safe, and log every action with timestamp and actor for the forensic and insurance record.
10. **Notify regulators.** Report the cyber incident to CERT-In within 6 hours as required by the CERT-In Directions of 28 April 2022; inform the Data Protection Board and affected persons under the DPDP Act 2023 if PHI is confirmed breached.

3.2 Employee Responsibilities (Roles and Accountability)

Role / Team	Responsibilities During the Incident	Reports To / Key Interfaces
Incident Commander (CEO / Medical Superintendent)	Declares the disaster, owns the overall decision, authorises emergency expenditure, approves diversion of patients and any external statement. Single point of final authority.	Board of Directors; chairs the EOC
CISO	Leads the cyber response: containment, eradication, forensic preservation, ransom-payment advice, regulatory notification, and the security sign-off before any system is reconnected.	Incident Commander; CERT-In; law enforcement
BCP Coordinator	Activates the plan, runs the EOC, tracks recovery against RTO, maintains the master incident log and escalation clock.	Incident Commander; all team leads
IT / DR Recovery Team	Executes server, database, network and backup recovery per Section 5; fails over to the DR site; rebuilds compromised hosts from clean images.	CISO and BCP Coordinator
Clinical Continuity Team (Chief Medical Officer, Nursing Superintendent)	Runs manual downtime clinical workflows, triage, re-prioritises the surgical list, ensures every paper record is later reconciled into the EHR.	Incident Commander
Facilities & Engineering	Water extraction and pumping, electrical isolation, generator and UPS restoration, fuel supply, medical-gas continuity, HVAC for the server room.	Incident Commander

Role / Team	Responsibilities During the Incident	Reports To / Key Interfaces
Pharmacy Lead	Manual prescription verification with a second-pharmacist double check, narcotics register, cold-chain protection with ice packs and portable refrigeration.	Chief Medical Officer
Laboratory Lead	Manual requisition and result flow, hand-delivered reports with two-person verification, prioritised STAT and pre-operative testing.	Chief Medical Officer
Communications / PR Officer	Single authorised voice to media and social platforms; issues holding statements and scheduled updates; monitors and corrects misinformation.	Incident Commander
HR Team	Staff accounting and safety, emergency roster, transport and accommodation for stranded staff, fatigue management, welfare support.	Incident Commander
Security Team	Manual access control while CCTV and biometrics are down; physical guard on the server room, pharmacy narcotics store and blood bank; crowd control at casualty.	Facilities Head
Legal & Compliance	Regulatory notification, insurance claim initiation, evidence retention, liaison with law enforcement and the cyber-insurance panel.	Incident Commander
All Employees	Report to duty station or the call tree, follow downtime procedures, do <i>not</i> speak to media or post on social media, do <i>not</i> reconnect any device to the network without IT clearance.	Respective team lead

3.3 Communication Plan

Audience	Channel (primary → fallback)	Frequency	Owner	Key Message
Internal staff	Public-address system → departmental call tree → SMS → WhatsApp broadcast → printed noticeboard	Immediate, then every 2 hours	BCP Coordinator / HR	Downtime mode is active; follow paper procedures; report status; do not reconnect devices
Clinicians on duty	Ward huddles + runners between departments	Every shift handover	Chief Medical Officer	Which systems are up, which are down, which manual form replaces which screen
Patients & families on site	Face-to-face help desks at casualty, OPD and each ward; printed notices in English and the local language	Continuous	Patient Relations	Care is continuing; expected delays; no clinical harm; no patient action required
Patients off site / appointment holders	Bulk SMS and IVR on the hospital helpline; hospital website banner	Within 2 hours, then daily	Communications Officer	Elective appointments rescheduled; emergency care remains open; alternative contact number
Media & social platforms	Official press statement; verified hospital handles only	First holding statement within 2 hours; updates every 4–6 hours	Communications Officer (approved by Incident Commander)	Confirmed facts only; what is being done; no speculation on cause, scope or attribution
Regulators (CERT-In, Data Protection Board, State Health Authority)	Formal written notification via the prescribed channel	CERT-In within 6 hours; others per statute	CISO / Legal	Nature of incident, systems affected, containment actions, preliminary impact assessment
Vendors & service partners	Emergency escalation numbers held offline in the printed call tree	Immediate	IT Manager	Disaster declared; invoke emergency SLA; dispatch engineers and spares

Audience	Channel (primary → fallback)	Frequency	Owner	Key Message
Insurers (cyber and property)	Claim hotline and broker	Within 24 hours	Legal / Finance	Notice of loss; evidence preservation confirmation
Partner hospitals & district EMS	Direct phone line to control room	Immediate	Chief Medical Officer	Diversion request, transfer capacity, mutual-aid activation

*Critical assumption to break: the communication plan must not depend on the failed infrastructure. Contact directories, escalation trees and vendor numbers are maintained as a **printed offline copy** in the EOC and in every department head's disaster folder, because email, intranet and the HIS are all unavailable exactly when they are needed.*

3.4 Alternate Working Arrangements

- **Alternate physical site:** relocate the command function and critical IT to an upper floor of the hospital (above flood level) with an independent generator; relocate clinical services from ground-floor wards upward.
- **Manual (downtime) clinical operations:** pre-printed downtime packs already staged in every ward — paper case sheets, medication administration records, lab and radiology requisitions, and a physical patient-tracking whiteboard per ward.
- **Standalone last-known-good data:** a read-only offline replica of the EHR (nightly export on an isolated laptop with a local printer in casualty) so that allergies, current medications and problem lists remain available even at full outage.
- **Connectivity workaround:** 4G/5G routers and mobile hotspots on a different carrier for essential terminals; a satellite link for the EOC.
- **Workforce arrangements:** extended-shift roster with mandatory rest rotation; on-campus accommodation and meals for stranded staff; remote working for administrative and billing functions once VPN with MFA is restored on clean devices.
- **Mutual-aid arrangements:** pre-signed MoUs with two nearby hospitals and a private diagnostic lab for surge overflow, urgent laboratory processing and imaging.
- **Alternate financial processing:** offline card terminals, UPI static QR, and manual numbered receipt books; deferred billing with post-incident reconciliation so discharge is never blocked by a payment system.

3.5 Recovery Strategy

Recovery proceeds in four sequential gates. No gate is entered until the previous one is verified.

Gate	Target Window	Actions	Exit Criterion
Gate 1 — Stabilise	0–2 hours	Life-safety power restored; flooding contained; ransomware contained by network isolation; EOC operational; downtime mode running hospital-wide	No patient at risk from loss of power or equipment; no further encryption observed
Gate 2 — Restore critical IT	2–12 hours	Fail over to the DR site; restore EHR read-only, then read-write; restore LIS and pharmacy; re-establish connectivity via a secondary link on a rebuilt, segmented network	Priority-1 services (BIA ranks 1–6) meeting their RTO on clean infrastructure
Gate 3 — Restore full service	12–72 hours	PACS, CCTV, billing and payment gateway, telemedicine, email and attendance restored; paper records back-entered into the EHR; data reconciled and gaps documented	All services restored; data integrity verified against the RPO; reconciliation complete
Gate 4 — Return & improve	3–30 days	Primary data centre rebuilt with flood-proofing and relocated above ground level; forensic root-cause report; insurance claim; BCP/DRP revision; staff retraining and a full-scale exercise	Board-accepted post-incident report with tracked corrective actions and revised plan

3.6 Vendor Coordination

Vendor / Partner	Role in Recovery	Required Contractual Provision
Internet Service Providers (primary + secondary)	Restore the last mile; provision an emergency 4G/5G or satellite link	Dual ISP on physically diverse routes; emergency restoration SLA of ≤ 4 hours with penalty clause

Vendor / Partner	Role in Recovery	Required Contractual Provision
HIS / EHR software vendor	Database recovery, integrity checks, application restart, downtime-data back-entry support	24×7 P1 support with a ≤ 30-minute response; named escalation contacts; source-code escrow
Hardware & network OEM	Replace flood-damaged switches, routers, storage and UPS	Next-business-day or 4-hour hardware replacement; buffer spares held on site above flood level
Generator / electrical AMC contractor	Emergency repair, load-bank testing, fuel replenishment	Monthly preventive maintenance with load-bank test evidence; emergency call-out clause; standby generator on hire
Cloud & backup provider	Supply clean immutable backups, cloud DR capacity, restore assistance	Immutable / WORM backup tier, geographic replication outside the coastal zone, documented restore SLA
Cybersecurity / DFIR firm	Forensic investigation, malware eradication, ransomware negotiation advisory, threat hunting before reconnection	Pre-signed retainer — a retainer signed <i>during</i> the incident costs days the hospital does not have
Cyber and property insurers	Loss recovery, funding of DFIR and business-interruption costs	Cyber policy with business-interruption cover; notification within the policy window; evidence-preservation compliance
Flood restoration / pumping service	Water extraction, drying, dehumidification, mould prevention, equipment salvage	Pre-monsoon standby agreement with priority call-out
Partner hospitals and diagnostic labs	Accept diverted patients; process urgent samples and imaging	Signed mutual-aid MoU reviewed annually before the monsoon

3.7 Patient Communication Strategy

Patients and families are the audience most likely to be harmed by the information vacuum. The strategy is **fast, factual and repetitive** — speed matters more than completeness, because the first credible voice sets the narrative.

- **Within 30 minutes (on site):** staffed help desks at casualty, OPD and every ward entrance. Verbal reassurance, printed bilingual notices, named point of contact per ward.
- **Within 2 hours (public):** a holding statement on the website and verified social handles — the hospital is experiencing a technical disruption caused by flooding, emergency care remains fully operational, patient safety is unaffected, and elective appointments are being rescheduled. Acknowledge, do not speculate.
- **Rumour correction:** actively monitor social media; respond to the specific false claim with a specific fact from the official handle. Never argue in comment threads; publish, link and move on.
- **Scheduled updates every 4–6 hours** even when there is no news — silence is read as concealment, and a predictable update rhythm removes the incentive to speculate.
- **Dedicated helpline** on a mobile network independent of the hospital PBX, staffed with a scripted FAQ and an escalation path to a clinician.
- **Breach notification:** if PHI exposure is confirmed, notify affected patients directly and specifically — what data, what risk, what the hospital is doing, what the patient should do — in the form and timeline required by the DPDP Act 2023. Do not pre-announce a breach that is not yet confirmed; do not delay one that is.
- **Post-recovery closure:** publish a summary of what happened, what was fixed and what will prevent recurrence. Trust is rebuilt by demonstrated correction, not by apology.

3.8 BCP Workflow Diagram

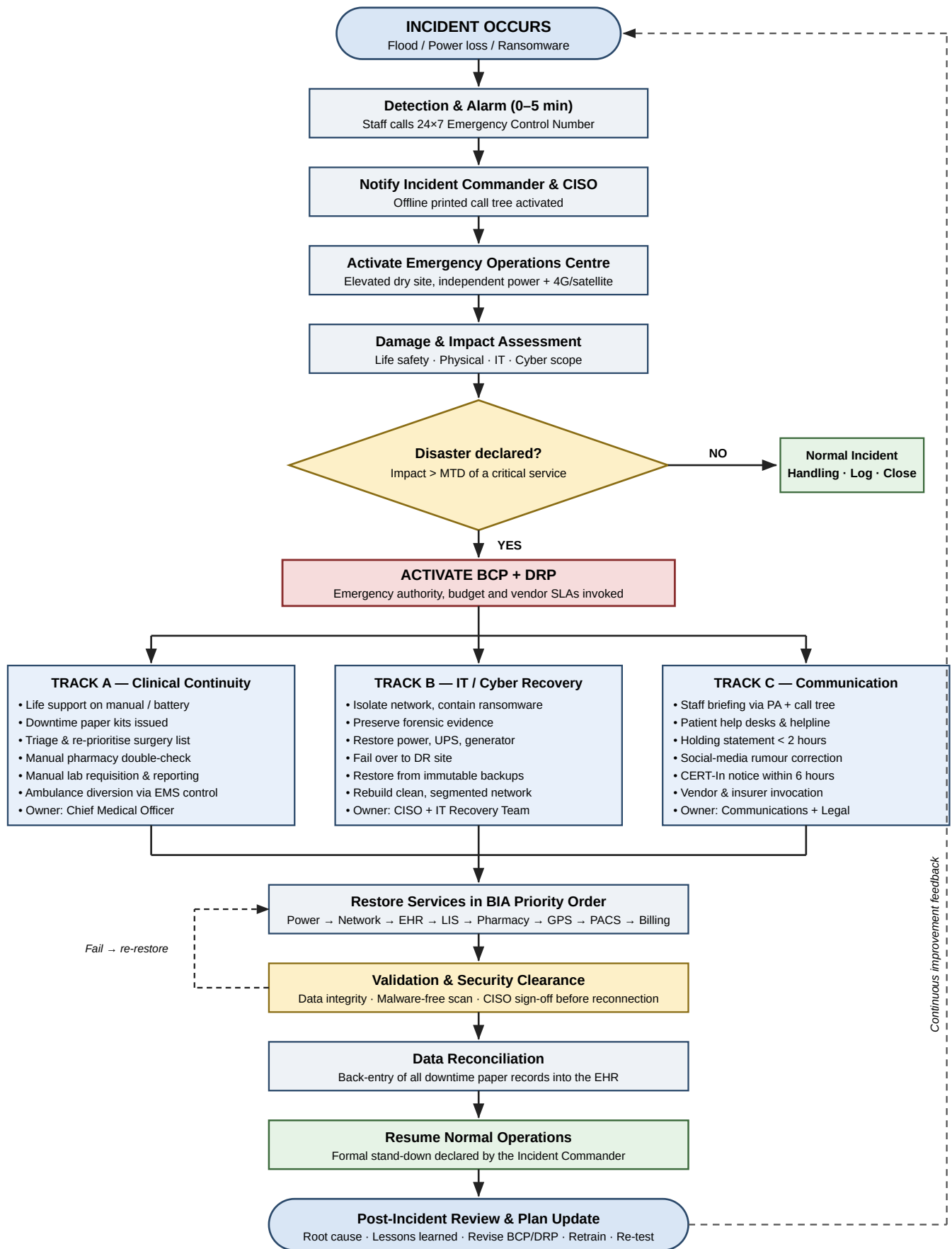


Figure 1 — Business Continuity Plan activation and recovery workflow

4. Risk Assessment (Risk Score = Likelihood × Impact)

Likelihood and Impact are each rated on a 1–5 scale. The product yields a risk score from 1 to 25, banded as follows:

Band	Score	Interpretation	Required Response
LOW	1–6	Acceptable	Monitor; periodic review
MEDIUM	8–12	Tolerable with controls	Mitigate within the planning cycle
HIGH	15–16	Unacceptable	Mitigate before the next monsoon; management sign-off
EXTREME	20–25	Intolerable	Immediate action; board-level escalation; halt-and-fix

Scale reference — Likelihood: 1 = Rare (< once in 10 years), 2 = Unlikely, 3 = Possible (once in 1–3 years), 4 = Likely (annually), 5 = Almost certain (every monsoon season). Impact: 1 = Negligible, 2 = Minor, 3 = Moderate, 4 = Major, 5 = Catastrophic (loss of life, or existential legal/financial harm).

#	Risk	Likelihood (1–5)	Impact (1–5)	Risk Score (L × I)	Rating	Mitigation Strategy
1	Flooding of the campus and water ingress into the server room	5	5	25	EXTREME	Relocate the data centre above the highest recorded flood level; install water-leak sensors, sump pumps, flood barriers and raised flooring; waterproof cable entries; move ground-floor critical assets upward before each monsoon. <i>Risk treatment: avoid + reduce.</i>
2	Ransomware encrypting file servers	4	5	20	EXTREME	3-2-1-1-0 backup rule with an immutable, air-gapped copy; EDR/XDR on all endpoints and servers; network segmentation isolating clinical VLANs; MFA on every remote and administrative access path; least-privilege and tiered admin accounts; monthly patching with an emergency out-of-band process; pre-signed DFIR retainer; quarterly restore drills. <i>Reduce + transfer (cyber insurance).</i>
3	Emergency generator failure due to improper maintenance	4	5	20	EXTREME	Monthly load-bank testing with documented evidence; N+1 generator redundancy; relocate generators and fuel tanks above flood level; automatic transfer-switch testing; minimum 72-hour fuel reserve with a priority refuelling contract; UPS runtime sized to cover generator start failure; maintenance compliance audited by the Facilities Head. <i>Reduce.</i>
4	Primary EHR database server unavailable (single point of failure)	4	5	20	EXTREME	High-availability database cluster with automatic failover; synchronous replication to the DR site; a read-only standby replica for clinical read access during any outage; transaction-log shipping every 15 minutes to meet the RPO; documented and rehearsed failover runbook. <i>Reduce.</i>
5	Loss of internet / WAN connectivity	4	4	16	HIGH	Dual ISPs on physically diverse last-mile routes with automatic failover via SD-WAN; 4G/5G backup on a different carrier; a satellite terminal for the EOC; contractual restoration SLA with penalty; ensure critical clinical systems degrade gracefully to a local-only mode rather than failing entirely. <i>Reduce.</i>
6	Phishing or weak remote access as the initial ransomware vector	4	4	16	HIGH	Mandatory MFA on VPN, RDP and email; disable direct RDP exposure; email filtering with attachment sandboxing and DMARC enforcement; quarterly simulated-phishing campaigns with targeted retraining; conditional access and geo-restriction; privileged-access management with just-in-time elevation. <i>Reduce.</i>

#	Risk	Likelihood (1–5)	Impact (1–5)	Risk Score (L × I)	Rating	Mitigation Strategy
7	Backup site located only 40 km away in the same coastal flood belt	3	5	15	HIGH	Relocate or add a tertiary DR site at least 250–300 km inland, outside the same weather system, power grid and telecom ring; or adopt a cloud DR region in a different geography. Retain the 40 km site as a warm near-site for fast recovery from localised failures. <i>Reduce</i> .
8	Backup integrity or restoration failure (unrecoverable data loss)	3	5	15	HIGH	Automated restore testing at least monthly with a documented success record; checksum and integrity verification on every backup job; immutable WORM storage and one offline copy; separate backup-system credentials never shared with the production domain; monitored and alerted backup job failures. An untested backup is a hypothesis, not a control. <i>Reduce</i> .
9	PHI breach and consequent regulatory penalty	3	5	15	HIGH	Encryption at rest and in transit; data-loss prevention on egress; strict role-based access with audit logging; data minimisation and retention limits; pre-drafted CERT-In and DPDP breach-notification templates; annual third-party security audit; documented lawful basis and consent records. <i>Reduce + transfer</i> .
10	Laboratory and pharmacy downtime causing clinical error or delayed surgery	3	5	15	HIGH	Pre-printed downtime forms staged in every department; an offline read-only clinical data terminal with printer in casualty, lab and pharmacy; mandatory two-person verification for manual dispensing and result reporting; quarterly downtime drills so manual mode is practised, not improvised; documented back-entry reconciliation procedure. <i>Reduce</i> .
11	Reputational damage from social-media misinformation	4	3	12	MEDIUM	Pre-approved holding-statement templates released within 2 hours; a single trained spokesperson; active social-listening during any incident; scheduled updates every 4–6 hours; a staff social-media policy prohibiting unauthorised comment; proactive engagement with local media and the health authority. <i>Reduce</i> .
12	Ambulance GPS tracking and dispatch failure	3	4	12	MEDIUM	Offline-capable mobile dispatch application with store-and-forward sync; VHF radio as an independent fallback channel; printed route maps with known flood-prone roads marked; direct voice line to the district EMS control room; monthly radio-check drill. <i>Reduce</i> .
13	Staff unavailability, fatigue and error during an extended event	4	3	12	MEDIUM	Pre-monsoon emergency roster with locally resident staff designated as first responders; on-campus accommodation, meals and transport; mandatory rest rotation enforced by HR; cross-trained multi-skilled staff; retainer with a nursing agency for surge staffing. <i>Reduce</i> .
14	Vendor or third-party SLA failure during a regional emergency	3	4	12	MEDIUM	Contractual emergency SLAs with penalty clauses and named 24×7 escalation contacts; dual-source critical vendors; on-site buffer spares for switches, routers and UPS modules; pre-monsoon vendor readiness review; annual joint recovery exercise with key vendors. <i>Reduce + transfer</i> .
15	Payment gateway outage and revenue interruption	3	3	9	MEDIUM	Offline card terminals and static UPI QR; manual numbered receipt books with post-incident reconciliation; a secondary payment aggregator; deferred-billing policy so discharge is never blocked by payment; business-interruption insurance cover. <i>Reduce + accept residual</i> .

#	Risk	Likelihood (1–5)	Impact (1–5)	Risk Score (L × I)	Rating	Mitigation Strategy
16	CCTV and biometric outage creating a physical security gap (theft, tampering)	3	3	9	MEDIUM	CCTV NVR on protected UPS power with local edge recording that survives network loss; battery-backed offline mode on access-control readers; manual guard posting and a written visitor register at restricted areas during any outage; mechanical key override for critical doors. <i>Reduce.</i>
17	Opportunistic theft or deliberate sabotage during degraded operations	2	4	8	MEDIUM	Increased physical guard deployment during declared emergencies; dedicated guard on the server room, narcotics store and blood bank; two-person rule for access to high-value areas; coordination with local police; asset tagging and post-incident physical inventory. <i>Reduce.</i>
18	Biometric attendance system outage	4	1	4	LOW	Manual muster roll with supervisor sign-off; retrospective reconciliation into the HR system; no continuity investment justified — explicitly accepted as a low risk with a documented workaround. <i>Accept.</i>

Risk treatment summary. Four EXTREME risks (scores 20–25) require immediate board-level action and must be closed before the next monsoon: data-centre relocation, ransomware resilience, generator reliability, and database high availability. Five HIGH risks (15–16) are scheduled within the current planning cycle. The remaining MEDIUM and LOW risks are managed through documented workarounds and periodic review. Residual risk after treatment is formally accepted and signed off by the Incident Commander and reviewed annually.

5. Disaster Recovery Plan (DRP)

The DRP is the technical execution arm of the BCP. Its governing rule in this scenario is that the event is **both physical and cyber**: recovery must never restore into the compromised environment, because doing so re-encrypts the restored data. Every restoration is therefore gated by a security clearance step.

5.1 Server Recovery

1. **Safety before salvage.** Confirm the electrical supply to the server room is isolated and standing water is pumped out before any physical access. Personnel enter only in appropriate PPE.
2. **Triage the hardware.** Classify every server as (a) undamaged, (b) water-damaged but salvageable, or (c) written off. Water-damaged units are not powered on — powering wet equipment destroys otherwise recoverable disks.
3. **Recover disks, not chassis.** Extract storage media from damaged servers for professional data recovery; treat the chassis as replaceable.
4. **Rebuild clean, never disinfect.** Ransomware-affected servers are rebuilt from known-good golden images on new or wiped hardware. Never reuse a potentially compromised operating system installation.
5. **Virtualise first.** Bring priority workloads up as virtual machines at the DR site or in the cloud so recovery does not wait for physical hardware procurement.
6. **Restore in dependency order:** domain controllers and identity → DNS/DHCP → database servers → application servers → integration and interface engines → reporting and ancillary servers.
7. **Harden before reconnecting:** latest patches, EDR agent installed and reporting, local administrator passwords rotated, unnecessary services and legacy protocols disabled, and all Kerberos/domain credentials reset (including the KRBTGT account, twice) before the server rejoins the production network.

5.2 Database Recovery

1. **Assess corruption and encryption scope.** Determine whether the EHR database files are physically damaged, logically corrupt, encrypted by ransomware, or simply unreachable due to network loss — the recovery path differs entirely.
2. **Promote the standby.** If the DR replica is intact and uninfected, promote it to primary to restore read-write service quickly, then re-establish replication in the reverse direction.
3. **Point-in-time recovery.** Where restoration from backup is required, restore the last clean full backup, apply differentials, then replay transaction logs to a timestamp *immediately before* the first indicator of compromise — not simply to "the latest", which would reintroduce the malware.
4. **Verify integrity.** Run database consistency checks (e.g. DBCC CHECKDB or equivalent), verify referential integrity, and confirm row counts and checksums against the last known-good report.
5. **Quantify the data gap.** Establish precisely which time window of transactions was lost, produce a written gap report, and hand it to the Clinical Continuity Team so paper records covering that window are prioritised for back-entry.
6. **Reconcile.** Back-enter downtime paper records with a dual-verification workflow; flag every back-entered record with its true clinical time and its entry time so the audit trail remains truthful.
7. **Re-establish protection.** Take an immediate full backup of the recovered database before it is exposed to users, and resume the normal backup schedule with verified job completion.

5.3 Backup Restoration

Step	Action	Control / Verification
Identify clean copies	Locate the most recent backup taken <i>before</i> the earliest indicator of compromise, using the DFIR-established compromise timeline	Restoring a post-compromise backup reinfests the environment — the timeline drives the choice, not the date
Verify immutability	Confirm the chosen copy resides on immutable / WORM or offline media that the attacker could not reach	Hash verification against the original backup catalogue

Step	Action	Control / Verification
Restore to an isolated environment	Restore first into a quarantined network segment with no route to production	Full anti-malware and IOC scan of the restored data before release
Validate application data	Application team confirms that patient records, orders, results and prescriptions are complete and consistent	Sample verification against printed downtime records
Promote to production	Move validated systems into the rebuilt production segment only after CISO sign-off	Formal written go/no-go decision, logged
Re-baseline backups	Take fresh full backups of all restored systems and confirm the first successful restore test	Documented restore test evidence within 72 hours

Target backup posture (3-2-1-1-0): 3 copies of data, on 2 different media, with 1 off-site copy outside the coastal hazard zone, 1 immutable or air-gapped copy, and 0 errors in the last verified restore test.

5.4 Network Recovery

1. **Keep the WAN down until cleared.** The external uplink stays disconnected until containment is confirmed; this both stops exfiltration and prevents re-entry through the attacker's command-and-control channel.
2. **Replace, do not dry.** Flood-damaged switches, routers, UPS units and patch panels are replaced from buffer spares or vendor emergency stock; water-exposed network hardware is not returned to service.
3. **Rebuild on a segmented design.** Restore the core with VLAN segmentation separating clinical systems, medical devices, administrative desktops, guest Wi-Fi and management interfaces, with firewall policy enforced between segments — the flat network is what let the ransomware spread.
4. **Restore connectivity in tiers:** EOC and clinical areas first, then laboratory and pharmacy, then administrative areas.
5. **Bring up redundant links:** activate the secondary ISP and SD-WAN failover; keep the 4G/5G and satellite paths live until the primary link is proven stable.
6. **Clean every endpoint.** All 250 desktops are scanned or re-imaged before being permitted back onto the network; network access control blocks any device without a current EDR heartbeat.
7. **Monitor intensively.** Restore firewall, IDS/IPS and log forwarding to the SIEM *before* reconnecting users, so the environment is observable from the first moment it is live, and threat-hunt for persistence mechanisms.

5.5 Recovery Site Strategy

Site Tier	Location	Type	RTO	Role and Limitation
Primary	Hospital campus data centre	Production	—	Currently flooded and compromised. Must be rebuilt above flood level with water sensors, barriers and raised flooring before it resumes primary status.
Secondary (existing)	40 km away	Warm site	4–12 hours	Usable for this event <i>if</i> it is unaffected — but it lies within the same coastal weather system and power grid, so it provides no protection against a regional event. Acceptable as a near-site, not as the only DR site.
Tertiary (recommended)	Inland, 250–300 km, different grid and telecom ring	Cloud DR / hot site	< 1 hour for Tier-1 services	Continuous asynchronous replication of the EHR, LIS and pharmacy databases; pre-provisioned virtual machines and infrastructure-as-code templates so capacity can be spun up on demand at low standing cost.
Immutable backup vault	Cloud object storage, separate credentials and separate tenancy	Cold / WORM	12–24 hours	Last line of defence against ransomware. Write-once, retention-locked, unreachable from the production domain even with domain-administrator credentials.
Alternate clinical site	Partner hospitals under mutual-aid MoU	Reciprocal	Immediate	Absorbs diverted patients and urgent laboratory and imaging workload while internal services are degraded.

5.6 Validation and Testing

(a) Post-recovery validation — before declaring any service restored

- **Technical validation:** service is reachable, performance is within normal baseline, integrations and HL7 interfaces are passing messages, and scheduled jobs are running.
- **Data validation:** record counts, checksums and referential integrity verified; the RPO gap is quantified and documented; sample records are reconciled against printed downtime forms.
- **Security validation:** full IOC and malware sweep clean, no unauthorised accounts or scheduled tasks, all credentials rotated, EDR reporting on every host, SIEM ingesting logs, and threat hunt completed — then formal CISO sign-off.
- **Clinical validation:** a designated clinician confirms end-to-end workflow — register a test patient, place an order, receive a result, dispense a prescription — before the system is released to ward use.
- **User acceptance:** department heads formally accept the restored service; only then is downtime mode stood down for that department.

(b) Ongoing testing programme — so the next event is rehearsed, not improvised

Test Type	Frequency	Scope and Success Criterion
Backup restore test	Monthly	Random sample restored to an isolated environment and verified; success criterion is a bit-verified restore with zero errors
Tabletop / walkthrough exercise	Quarterly	Scenario-driven discussion with all team leads; validates decision authority, escalation and the call tree
Clinical downtime drill	Quarterly	Wards operate on paper for a defined period; validates that downtime kits exist, are current, and that staff can use them
DR failover test	Half-yearly	Actual failover of the EHR to the DR site with measured RTO and RPO; success criterion is meeting the documented objectives
Full-scale simulation	Annually, pre-monsoon	Combined flood + cyber scenario involving clinical, IT, facilities, communications and vendors end to end
Generator load-bank test	Monthly	Full-load run with documented evidence — the control whose absence caused failure in this incident
Vulnerability assessment & penetration test	Half-yearly	External and internal testing with tracked remediation of all high and critical findings
Plan review and update	Annually or after any incident	BCP/DRP revised against lessons learned; contact lists, RTO/RPO values and vendor SLAs re-validated

6. CISO Crisis Management Strategy — First 24 Hours

The following is the phased strategy I would execute as CISO. The organising principle across all phases: **protect life first, contain second, communicate third, recover fourth, and preserve evidence throughout**. Each phase has a defined objective, so that progress is measured against outcomes rather than activity.

Phase 1 — First 30 Minutes: Detect, Protect Life, Contain

Objective: stop the bleeding. Nobody dies, and nothing further gets encrypted.

Activity	Responsible Team	Expected Outcome
Confirm the incident and declare a crisis; activate the EOC at the elevated dry site	CISO + Incident Commander	Single recognised command structure in place; no parallel decision-making
Ensure life-support continuity — manual ventilation, battery monitors, oxygen supply verified	Clinical Continuity Team + Facilities	Zero patient deterioration attributable to the outage
Emergency network isolation: disconnect the WAN uplink, segment or shut down affected VLANs	IT / Network Team (CISO directive)	Ransomware propagation halted; exfiltration channel severed
Electrically isolate the flooded server room; prohibit entry	Facilities & Engineering	No electrocution risk; no further equipment damage
Activate the printed call tree; recall key personnel	BCP Coordinator + HR	Core response teams mobilised without relying on email or the intranet
Announce hospital-wide switch to Downtime Mode over the PA system	BCP Coordinator	Every ward on paper procedures within 30 minutes
Preserve volatile evidence — photograph the ransom note, capture memory and logs where safe	CISO + IT Security	Forensic chain of custody established from the outset
Instruct all staff: do not pay, do not negotiate, do not power-cycle affected systems, do not post publicly	CISO	Evidence preserved; no uncontrolled disclosure

Phase 2 — First 2 Hours: Assess, Organise, Speak First

Objective: know the true scope, and be the first credible source of information.

Activity	Responsible Team	Expected Outcome
Complete damage and impact assessment across physical, IT, cyber and clinical dimensions	All team leads → EOC	Written scope statement: what is down, what is encrypted, what is intact
Determine whether the 40 km DR site and the backup repository are clean and reachable	IT / DR Team	Recovery path selected: DR failover vs. restore from backup
Engage the DFIR retainer, cyber insurer and legal counsel	CISO + Legal	Expert forensic support mobilised; insurance notice given within the policy window
Issue the first holding statement to staff, patients and media	Communications Officer (Incident Commander approval)	Hospital owns the narrative before rumour hardens; panic reduced
Stand up patient help desks and the independent helpline	Patient Relations	On-site families informed; call volume absorbed away from clinical staff
Invoke vendor emergency SLAs — ISP, HIS vendor, hardware OEM, generator AMC	IT Manager + Procurement	Engineers and spares dispatched; recovery resources committed in writing
Request ambulance diversion for non-critical cases via the district EMS control room	Chief Medical Officer	Incoming load matched to degraded capacity
Restore emergency power to life-safety circuits (hired standby generator if required)	Facilities	ICU, OT and critical care on stable power

Phase 3 — First 6 Hours: Contain Fully, Notify, Begin Recovery

Objective: eradication underway, statutory obligations met, first critical service back on clean infrastructure.

Activity	Responsible Team	Expected Outcome
Submit the CERT-In incident notification within the mandatory 6-hour window	CISO + Legal	Statutory compliance achieved; regulatory exposure limited
Establish the compromise timeline — patient zero, initial access vector, dwell time, encryption start	DFIR firm + IT Security	The clean-backup cut-off point is known, so restoration cannot reintroduce the malware
Reset all credentials: domain, service, administrative and remote-access accounts; rotate KRBTGT twice	IT Security	Attacker persistence via stolen credentials removed
Begin DR site failover; restore the EHR in read-only mode first	IT / DR Team	Clinicians regain access to history, allergies and medications — the largest clinical risk retired
Restore connectivity over the secondary link on a rebuilt, segmented network	Network Team	Controlled connectivity restored without reopening the original attack path
Assess whether PHI was exfiltrated	DFIR + CISO	Evidence-based decision on whether DPDP breach notification is triggered
Second public update; active correction of social-media misinformation	Communications Officer	Rumour of "systems hacked and patient data leaked" answered with verified facts
Deploy manual physical security to the server room, narcotics store and blood bank	Security Team	Physical security gap from CCTV and biometric outage compensated

Phase 4 — First 12 Hours: Restore Critical Clinical Services

Objective: every High-priority BIA service operating on verified-clean infrastructure.

Activity	Responsible Team	Expected Outcome
Promote the EHR to full read-write on clean infrastructure after integrity and malware validation	IT / DR Team + HIS vendor	Orders, notes and admissions flowing digitally again
Restore the Laboratory Information System and analyser interfaces	IT + Laboratory Lead	Pre-operative and cross-match reports available; the blocked surgical queue clears
Restore pharmacy management and prescription verification	IT + Pharmacy Lead	Automated drug-interaction checking resumes; medication-error risk falls
Restore ambulance GPS tracking and dispatch	IT + Transport	Fleet visibility regained; routing around flooded roads restored
Re-image or scan all 250 desktops before permitting network access	IT Support	No reinfection from an unremediated endpoint
Deploy EDR and SIEM log forwarding across the rebuilt estate; begin continuous threat hunting	IT Security	Environment is observable and monitored from the moment it is live
Begin back-entry of downtime paper records into the EHR	Clinical + Health Information Management	Record continuity restored; the RPO data gap documented and closing
Staff rotation and fatigue management; relief shift deployed	HR	Error rate controlled; response sustainable beyond the first day

Phase 5 — First 24 Hours: Stabilise, Verify, Prepare the Handover

Objective: hospital operating on restored systems with a verified security posture, and a written record ready for management, regulators and insurers.

Activity	Responsible Team	Expected Outcome
Restore Medium-priority services — PACS, CCTV, billing and payment gateway, email	IT Team	Revenue cycle and physical monitoring resumed
Complete validation: technical, data, security and clinical sign-off per service	CISO + department heads	Formal, documented acceptance rather than an informal assumption that things work
Full-environment threat hunt and vulnerability scan; confirm no residual persistence	IT Security + DFIR	Written all-clear before the environment is considered stable
Verify backups of all restored systems and execute a test restore	IT / Backup Team	The hospital is protected against a second encryption event during recovery
File the preliminary incident report with management, CERT-In follow-up, insurers and the health authority	CISO + Legal	Regulatory and contractual obligations discharged with an evidenced timeline
Issue the patient and public update; begin individual breach notification if exfiltration is confirmed	Communications + Legal	Transparent, legally compliant disclosure; reputational damage contained
Decide formally on the ransom: recommendation is do not pay where clean backups are restorable	Incident Commander (CISO advice)	Documented, defensible decision — payment funds further attacks and offers no guarantee of decryption
Complete data reconciliation and publish the RPO gap report	Health Information Management	Clinicians know exactly which window of records is paper-only
Structured handover to the next command shift; schedule the post-incident review	Incident Commander + BCP Coordinator	Continuity of command beyond 24 hours; lessons-learned process initiated

Expected position at the end of 24 hours. All High-priority clinical services (Emergency care, EHR, LIS, Pharmacy, Network, Ambulance GPS) are restored on clean, segmented infrastructure. Ransomware is contained and eradicated with no observed persistence. CERT-In notification is filed within the statutory 6-hour window. No patient harm is attributable to the outage. The public narrative is owned by the hospital rather than by social media. A documented evidence trail exists for the forensic, insurance and regulatory processes, and the recovery is handed over with a written status rather than verbally.

Principal lesson. The flood was the trigger, but the damage was determined by pre-existing control gaps — a data centre at flood level, untested generators, a DR site inside the same hazard zone, unverified backups and a flat network. Business continuity is not what an organisation does during a disaster; it is what it built before one.

Standards and references applied: ISO 22301:2019 (Business Continuity Management Systems) · ISO/IEC 27001:2022 & 27002:2022 (Information Security Controls) · ISO/IEC 27005 (Information Security Risk Management) · NIST SP 800-34 Rev.1 (Contingency Planning) · NIST SP 800-61 Rev.2 (Computer Security Incident Handling) · CERT-In Directions dated 28 April 2022 (6-hour incident reporting) · Digital Personal Data Protection Act, 2023 · Information Technology Act, 2000 (§43A, §72A) · NABH Accreditation Standards for Hospitals (Information Management System chapter).